TRUSTED PLATFORM MODULE REDESIGN

Contents

Introduction 2

Key Detection, Response and Recovery Systems 3

Low Power Mode and Tamper Detection Systems 4

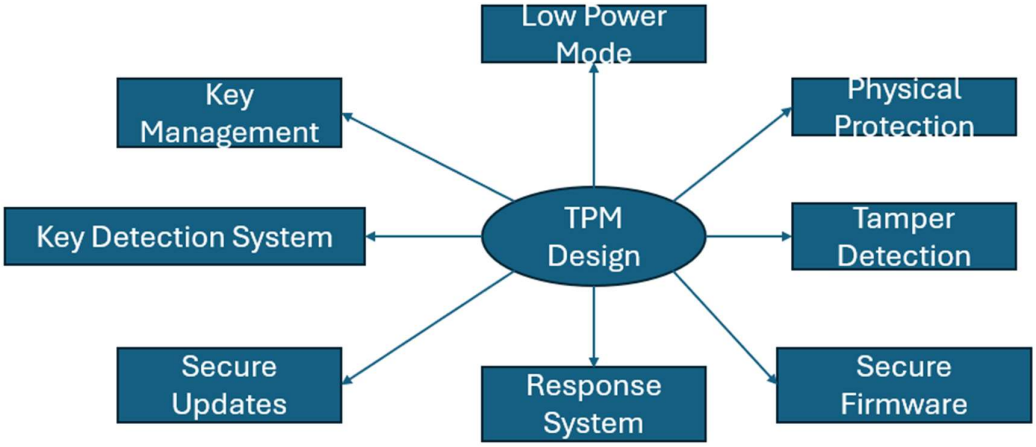
Key Management and Update Systems 5

TPM Design Trade-offs 6

Introduction

This TPM design is designed to create a trusted platform module that is more secure and reliable especially within high-risk environments. This design was created as it is critical for key management within a device. It is also important as the RAM encryption mode relies on it heavily. This design does not change the purpose or the main components within the trusted platform module. Instead, this design focuses on coordination with the operating, more secure key storage and protection against physical attacks.

This TPM design cannot promise perfect security or reliability just like all my other designs I have created. However, this TPM design can promise to try improving security as much as possible. This TPM design specification is specifically made for engineers to use. Make sure to adapt this design to real-life implications that may occur during its implementation.



The diagram above shows the main concepts involved within this trusted platform module design. We can specifically see that this key management focuses on verification, protection against tampering and responding compared to just improving the hardware of the TPM. There will be more information in the sections below.

Key Detection, Response and Recovery Systems

- **There will be 3 systems that I will discuss with this section.**
- **The first system is the key detection system.**
- **This key detection system is designed to check for the keys are present within the TPM.**
- **This key detection system uses the operating system and microcontroller within the TPM to check for the presence of keys.**
- **The microcontroller uses the encryption algorithm EdDSA to generate each signature for all the keys.**
- **The OS stores the public key within firmware or within other secure storage to be able to verify the presence.**
- **However, this presence check should not mark a key as missing if an authorised process where the key needs to be temporarily in RAM is approved.**
- **It is important that the OS cannot extract the keys using the signatures and only can use the public key to perform a presence check.**
- **This key detection system is needed as it ensures that the keys are within TPM and haven't been extracted or lost.**
- **The second system is the response system.**
- **This response system is designed to automatically act if the presence check for the keys have failed.**
- **This response system mainly uses the operating system and rarely the microcontroller.**
- **This response system triggers if the key is not in TPM and there is no authorised operation where they should be.**
- **If the operating system is available, it may perform actions such as alert the user that the key is missing or rotate the key automatically if possible.**
- **If the operating system is not available, the microcontroller may automatically wipe keys to protect itself against tampering.**
- **This response system most of the time should alert the user to prevent the risk of a complete false positive.**
- **This response system is needed to ensure that swift action can be taken before an attacker can use a key to decrypt sensitive data.**
- **The third system is the recovery system**
- **This recovery system requires the operating system and the user to operate effectively.**
- **This recovery system generates a one-time key at start-up that the user can use to decrypt their contents if they lose the main key.**
- **The operating system does not retain the recovery key for security meaning it is up to the user to store securely.**
- **If the user loses their main key, they can use the recovery key which allows the operating system to decrypt the contents.**

Low Power Mode and Tamper Detection Systems

- **In this section, I will be discussing the TPM's low power mode and tamper detection system.**
- **The first system I will discuss is the low power mode**
- **Low power mode is a state where the TPM is constantly active and can perform functions using its microcontroller.**
- **This low power mode relies on device power when the device is on and on a battery when device power is not available.**
- **This battery on the TPM must be small and can be charged when the device itself being charged.**
- **This microcontroller runs its own firmware code allowing the TPM to perform cryptographic tasks.**
- **This low power mode is needed as it allows the TPM to run the response system, detection system and tamper detection.**
- **This is important because the TPM needs to protect itself from digital and physical attacks that can occur.**
- **The second system I will discuss is the tamper detection system**
- **The tamper detection system is designed to detect any sort of physical tampering on the TPM.**
- **This tamper detection system will use a different range of sensors and low power mode to operate.**
- **For motion, the TPM will have motion sensors to detect physical tampering with the TPM.**
- **For repairs, the operating system can have a feature where the user must authenticate allowing a temporary set window to allow motion needed for repairs.**
- **If motion is detected outside of this window, then the TPM may wipe all its key or rely on the response system and alert the user.**
- **For power analysis, the TPM can use a CSA which can measure the voltage and lower or increase battery usage based on the tasks being done.**
- **For temperature, a on-die temperature sensor can be integrated within the TPM's processor allowing to monitor the temperature.**
- **If the temperature becomes too high or too low, the TPM can wipe or shut down to save itself from damage or compromise.**
- **For EM, the TPM can have a on-die EM sensor directly integrated with the TPM's processor to detect EM.**
- **This allows the TPM to detect its own EM patterns which allows it to check if any components outside of the TPM are emitting the same patterns.**
- **If the TPM detects that there is a device emitting the same patterns, it may deploy false EM signals or use the response system to respond.**
- **This system is needed to protect the TPM from side-channel attacks.**

Key Management and Update Systems

- **In this section, I will be discussing how the TPM will manage the keys and how its firmware and updates are secured and verified.**
- **The first system I will be discussing is key management.**
- **The key management system is designed to ensure that an attacker cannot extract the key without it being extremely expensive.**
- **This key management system relies completely on the TPM as the key will never leave TPM.**
- **First, all keys within TPM are encrypted using separate parent key for each one with RSA or ECC encryption algorithms being used.**
- **This ensures that if the parent key for one key is compromised, no other keys within the TPM is compromised.**
- **Second, keys within the TPM can only be used after the user authenticates using a password or other authentication method.**
- **This ensures that an attacker cannot just easily use a key to decrypt contents on a device.**
- **Third, if the key were to ever leave TPM, it would remain encrypted to ensure that an attacker cannot extract them from areas with lower security.**
- **This is important because it ensures if an attacker manages to extract it, they still must crack the encryption.**
- **This key management system is needed to ensure that the keys within TPM are stored safely and cannot be extracted easily.**
- **The second system I will be discussing is updates.**
- **This update system is designed to ensure that an attacker cannot push through malicious updates to TPM firmware.**
- **First, the user can choose when to install firmware updates through the provider or directly through the operating system.**
- **This is important to ensure that updates don't disrupt user functions too much and give them time to be adaptive.**
- **Second, once an update is accepted by the user, the operating system uses a public key to verify the first signature on the update.**
- **If the OS's verification is a success, the update is forwarded to the TPM's processor.**
- **Third, the TPM's processor uses its public key to verify the second signature on the update.**
- **If the TPM's verification is correct, the update is installed on the TPM allowing to function more effectively.**
- **For the case, where verification does fail, the update is discarded and normal operation continues**
- **This update system is needed to ensure that the firmware of the TPM stays updated with the latest patches while also ensuring no malicious updates can be pushed to its firmware.**

TPM Design Trade-offs

- **This TPM design has trade-offs just like any other system I have created.**
- **I have identified 5 main trade-offs.**
- **The first trade-off is false positives.**
- **This trade-off exists as the system can falsely fail verification or detect tampering causing wipes or responses.**
- **This means that the users may lose data since all the keys would be wiped by the TPM's processes.**
- **This trade-off can be managed by using recovery keys as backup, having response systems alert users or using other actions and using wiping as last resort.**
- **The second trade-off is complexity.**
- **This trade-off exists as this TPM design requires changes to firmware logic, OS logic and multiple sensors physically on the TPM.**
- **This means that engineers and developers may struggle to understand and implement the systems correctly leading to misconfigurations.**
- **This trade-off can be managed by using phased implementation, clear communication between teams and structured project management processes.**
- **The third trade-off is performance.**
- **This trade-off exists as this TPM design uses verification at multiple stages within all the systems.**
- **This means that the TPM's performance will decrease as more work must be done before operations can be executed.**
- **This trade-off can be managed by using fast encryption algorithms for verification, clear separation of responsibilities and purposeful and efficient coding.**
- **The fourth trade-off Is compatibility.**
- **This trade-off exists as TPMs will not be compatible for all devices especially more legacy models.**
- **This means that not all users will be able to have the security benefits that TPM will offer with this design.**
- **This trade-off can be managed by accepting the compatibility trade-off and attempting to make the TPM as compatible with other components as possible.**
- **The fifth and final trade-off is limited power.**
- **This trade-off exists as this TPM design without device power operates on a battery which is limited.**
- **This means that eventually without charging the battery will die and the TPM's lower power mode will shut off.**
- **This trade-off can be managed by efficient battery usage, power monitoring and low power mode which are all integrated within this TPM design.**
- **It is important to remember that there may be more trade-offs.**